

Plan d'Audit Interne SMSI — TechShop SAS

Version : 1.0
Date : Juin 2026
Auteur : Dorian Poncelet (Consultant GRC)
Statut : Validé
Référence : ISO 27001:2022 — Clause 9.2 (Audit interne)

Fondements de l'audit interne ISO 27001

Pourquoi l'audit interne est obligatoire

La clause 9.2 d'ISO 27001 exige que l'organisation réalise des audits internes à ****intervalles planifiés**** pour vérifier que le SMSI :

- a) Est conforme aux exigences de la norme ISO 27001
- b) Est conforme aux exigences propres de l'organisation (politiques internes)
- c) Est efficacement mis en ?uvre et tenu ? jour

Sans programme d'audit interne documenté et réalisé, **la certification ISO 27001 est impossible**.
C'est l'une des premières choses qu'un auditeur de certification demande.

Indépendance de l'auditeur

ISO 27001 exige que les auditeurs soient **indépendants** des activités auditées.
Pour TechShop SAS (47 salariés, DSI unique) :

Option	Faisabilité	Coût	Indépendance
DSI audite son propre périmètre	[NON] Interdit	0 €	Nulle
DPO audite les contrôles IT	[!] Partiel	0 €	Partielle
Consultant externe (1ère année)	[OK] Recommandé	1 500–3 000 €	Totale
Croisement avec autre PME (peer audit)	[OK] Innovant	0 €	Bonne

Décision TechShop SAS : Pour le premier audit interne (2026), recours à un consultant externe indépendant. À partir de 2027, formation d'un auditeur interne (DPO ou responsable qualité) via certification ISO 27001 Lead Auditor.

Programme d'audit — 12 mois (Juillet 2026 – Juin 2027)

Logique de planification

Le programme couvre l'ensemble du SMSI sur 12 mois, découpé en **4 audits thématiques** et **1 audit de clôture** avant la revue de direction annuelle.

Juillet 2026	Octobre 2026	Janvier 2027	Avril 2027	Juin 2027
?	?	?	?	?
?	?	?	?	?
AUDIT A-01	AUDIT A-02	AUDIT A-03	AUDIT A-04	REVUE DIR.
Gouvernance & Organisation	Technique & Vulnérabilités	Conformité RGPD/NIS2	Continuité & Incidents	Synthèse annuelle
(2 jours)	(2 jours)	(1 jour)	(1 jour)	(1/2 jour)

AUDIT A-01 — Gouvernance et Organisation

Date prévue : Semaine du 14 juillet 2026
Durée : 2 jours
Auditeur : Consultant externe indépendant
Périmètre : Clauses ISO 27001 : 4, 5, 6, 7, 9, 10 + Contrôles A.5, A.6

Objectifs

- Vérifier que le contexte organisationnel est documenté (Clause 4)
- Vérifier l'engagement de la direction (Clause 5)
- Vérifier que l'analyse de risques est complète et à jour (Clause 6)
- Vérifier que les ressources et compétences sont en place (Clause 7)

Programme détaillé

Heure	Activité	Interlocuteurs	Documents à examiner
Jour 1			
09h00	Réunion d'ouverture	DG, DSI, DPO	—
09h30	Contexte et périmètre SMSI	DG	Declaration-perimetre.md
10h30	Politique de sécurité	DG + DSI	politique-securite.md
11h30	Rôles et responsabilités	DG + DRH	Organigramme, fiches de poste
14h00	Analyse de risques (EBIOS RM)	DSI	registre-risques.md

Heure	Activité	Interlocuteurs	Documents à examiner
15h30	Statement of Applicability (SoA)	DSI	SoA-iso27001.md
16h30	Plan de traitement des risques	DSI	plan-traitement-risques.md
Jour 2			
09h00	Inventaire des actifs	DSI	inventaire-actifs.md
10h00	Sensibilisation et formation sécurité	DRH + DSI	Registres de formation, émargements
11h00	Contrôles A.6 (personnes)	DRH	Contrats, NDA, procédure offboarding
14h00	Programme d'amélioration continue	DSI	Actions correctives, suivi PTR
15h30	Compilation des findings	Auditeur seul	—
16h30	Réunion de clôture J1	DSI, DPO	Présentation findings préliminaires

Critères d'audit

- ISO 27001:2022 Clauses 4 à 10
- Politique de sécurité TechShop SAS
- Registre des risques v1.0

AUDIT A-02 — Technique et Gestion des Vulnérabilités

Date prévue : Semaine du 6 octobre 2026

Durée : 2 jours

Auditeur : Consultant externe indépendant (compétences techniques requises)

Périmètre : Contrôles A.8 (technologiques) — focus : A.8.5, A.8.7, A.8.8, A.8.13, A.8.20

Objectifs

- Vérifier le déploiement effectif du MFA (M01)
- Vérifier la gestion des vulnérabilités et le patch management (M10)
- Vérifier les sauvegardes et l'Object Lock S3 (M03)
- Vérifier la segmentation réseau (M09)
- Vérifier le déploiement EDR (M06)

Programme détaillé

Heure	Activité	Méthode	Preuves attendues
Jour 1			
09h00	Réunion d'ouverture	Entretien	—
09h30	Vérification MFA Google Workspace	Observation directe Admin Console	Rapport GW "100% MFA"
10h30	Vérification MFA AWS + OVH	Observation	Captures IAM + OVH Manager

Heure	Activité	Méthode	Preuves attendues
11h30	Revue politique patch management	Entretien DSI + documentation	Politique écrite + journal MAJ
14h00	WPScan — revue des rapports	Analyse rapports	Rapports WPScan mensuel
15h00	Vérification plugins WordPress	Observation Admin WP	Liste plugins + dates MAJ
16h00	Vérification Cloudflare WAF mode Block	Observation	Capture dashboard Cloudflare
Jour 2			
09h00	Test de restauration backup (échantillon)	Test en direct	Restauration BDD test réussie
11h00	Vérification S3 Object Lock	Observation AWS Console	Capture Object Lock activé
14h00	Architecture réseau et VLAN WiFi	Observation + schéma réseau	Schéma réseau à jour
15h00	Revue logs et supervision Grafana	Observation	Dashboard Grafana actif
16h00	Réunion de clôture	DSI	Findings préliminaires

Critères d'audit

- ISO 27001:2022 Contrôles A.8 (technologiques)
- Plan de traitement des risques — Mesures M01, M03, M06, M09, M10
- KRI-01 à KRI-03 du tableau de bord

AUDIT A-03 — Conformité RGPD et NIS2

Date prévue : Semaine du 12 janvier 2027

Durée : 1 jour

Auditeur : DPO (Sophie Blanc) — domaine RH/juridique hors périmètre DSI

Périmètre : RGPD Art. 5, 13, 28, 30, 32, 33, 46 / NIS2 Art. 21

Objectifs

- Vérifier la conformité du registre des traitements (Art. 30)
- Vérifier la correction des transferts hors UE (NC-01, NC-02)
- Vérifier les droits des personnes (Art. 15-22)
- Vérifier la procédure de notification d'incident CNIL (Art. 33)
- Vérifier l'avancement NIS2 Article 21

Programme détaillé

Heure	Activité	Méthode	Preuves attendues
09h00	Réunion d'ouverture	Entretien DPO + DSI	—
09h30	Registre des traitements	Revue documentaire	rgpd-conformite.md à jour

Heure	Activité	Méthode	Preuves attendues
10h30	Transferts hors UE	Vérification technique	AWS Config (0 bucket us-east-1) + HubSpot DPA
11h30	Bandeau cookies CNIL	Test sur site web	Capture bandeau conforme
14h00	Droits des personnes	Entretien + test	Page "Exercer mes droits" opérationnelle
15h00	Procédure notification CNIL 72h	Simulation	Procédure écrite + exercice documenté
15h30	Avancement NIS2 Art. 21	Revue documentaire	nis2-article21.md mis à jour
16h00	Réunion de clôture	DPO + DSI	Findings

Critères d'audit

- RGPD Règlement UE 2016/679
- Directive NIS2 2022/2555 Article 21
- Registre des traitements TechShop SAS v1.0

AUDIT A-04 — Continuité et Gestion des Incidents

Date prévue : Semaine du 7 avril 2027

Durée : 1 jour

Auditeur : Consultant externe (ou DPO si formé)

Périmètre : ISO 27001 Clauses A.5.24–A.5.30 / NIS2 Art. 21 (b) et (c)

Objectifs

- Vérifier que le PRA est documenté et testé (M12, M07)
- Vérifier la procédure de gestion des incidents (P1/P2/P3)
- Vérifier le canal de signalement interne (sécurité@techshop.fr)
- Simuler un exercice de crise (ransomware fictif)

Programme détaillé

Heure	Activité	Méthode	Preuves attendues
09h00	Réunion d'ouverture	Entretien DSI + DG	—
09h30	Revue PRA documenté	Revue documentaire	PRA signé avec RTO/RPO
10h30	Résultats test restauration (M07)	Revue rapport	Rapport test trimestriel
11h30	Procédure gestion des incidents	Entretien + doc	Procédure P1/P2/P3 écrite
14h00	Exercice de crise — Scénario ransomware	Simulation 1h	Déroulement documenté
15h00	Debriefing exercice	DSI + DG	Points forts / axes d'amélioration

Heure	Activité	Méthode	Preuves attendues
15h30	Canal de signalement interne	Test	Email sécurité@techshop.fr fonctionnel
16h00	Réunion de clôture	DSI	Findings

Scénario de l'exercice de crise (ransomware fictif)

SCENARIO : Il est 08h30. Thomas Rivet (DSI) reçoit une alerte Grafana :
"Les serveurs OVH WooCommerce ne répondent plus.
Des fichiers .encrypted sont détectés dans /var/www/html."

Questions testées :

1. Qui est le premier alerté ? (chain of command)
2. Comment on isole les serveurs compromis ?
3. Qui décide d'activer le PRA ?
4. Comment on communique aux clients (si données potentiellement exposées) ?
5. Quand et comment on notifie la CNIL ?
6. Comment on restaure depuis S3 Object Lock ?
7. Qui gère la communication externe (site down, réseaux sociaux) ?

Gestion des findings d'audit

Classification des findings

Niveau	Définition	Délai de correction
Non-conformité Majeure	Absence complète d'un contrôle requis par ISO 27001 OU situation créant un risque immédiat	30 jours
Non-conformité Mineure	Contrôle partiellement implémenté ou preuve insuffisante	90 jours
Observation	Amélioration recommandée, pas d'obligation normative	6 mois
Point positif	Bonne pratique à conserver et à étendre	N/A

Template de rapport d'audit

%%
RAPPORT D'AUDIT INTERNE SMSI ? TECHSHOP SAS
%%
Audit n? : A-0X
Date : JJ/MM/AAAA
Auditeur : [Nom + qualification]
Périmètre : [Clauses et contrôles audités]
%%
SYNTHÈSE EXÉCUTIVE
Findings critiques : X
Non-conformités : X majeures / X mineures
Observations : X
Points positifs : X
%%

Revue de Direction — Juin 2027

La revue de direction (Clause 9.3 ISO 27001) est distincte de l'audit interne.

Elle a lieu après la dernière série d'audits et rassemble la direction pour décider.

Ordre du jour type

#	Sujet	Durée	Participants
1	Résultats des 4 audits internes 2026-2027	30 min	DG, DSI, DPO
2	État du tableau de bord KRI/KPI	20 min	DSI
3	Actions correctives ouvertes	15 min	DSI
4	Évolution du contexte (nouvelles menaces, NIS2)	15 min	DPO
5	Révision des objectifs de sécurité 2027-2028	20 min	DG + DSI

#	Sujet	Durée	Participants
6	Décision sur les risques résiduels acceptés	15 min	DG
7	Budget sécurité 2027	15 min	DG + DSI

Décisions obligatoires en revue de direction

ISO 27801 Clause 9.3 exige que la revue produise des décisions sur :

- ? Opportunités d'amélioration continue
- ? Tout besoin de changement du SMSI
- ? Ressources nécessaires
- ? Révision de la politique de sécurité si nécessaire

Synthèse du programme d'audit

Audit	Date	Durée	Périmètre principal	Auditeur
A-01 Gouvernance	Juillet 2026	2 jours	Clauses 4-10, A.5, A.6	Consultant externe
A-02 Technique	Octobre 2026	2 jours	A.8, MFA, backup, WAF	Consultant externe
A-03 RGPD/NIS2	Janvier 2027	1 jour	RGPD + NIS2 Art. 21	DPO
A-04 Continuité	Avril 2027	1 jour	PRA, incidents, exercice crise	Consultant externe
Revue Direction	Juin 2027	1/2 jour	Synthèse annuelle	DG + DSI + DPO
Total		6,5 jours	SMSI complet	

Budget programme d'audit :

Poste	Coût estimé
3 jours consultant externe (A-01 + A-02)	2 500 – 4 500 €
1 jour consultant A-04	800 – 1 500 €
Charge interne DPO (A-03)	0 €
Formation Lead Auditor interne (2027)	1 500 – 2 500 €
Total budget audit 2026-2027	4 800 – 8 500 €

Document produit dans le cadre du SMSI TechShop SAS — Projet portfolio GRC Automation

Programme à réviser après chaque cycle annuel — Prochaine révision : Juin 2027